BOMBUS HRM

組織架構、帳號管理
角色權限與平台管理

系統設定與 SaaS 平台管理的完整功能介紹

適用對象：平台管理員 / 系統管理員 / 子公司管理員　　模組：系統設定 + 平台管理

平台管理者、租戶與角色的關係

Bombus 採用 Database-per-Tenant 多租戶 SaaS 架構，以下定義各層級角色與上下關係。

平台管理員 (Platform Admin)

SaaS 營運者 — 管理所有租戶的生命週期

建立租戶 | 方案管理 | 平台審計

建立並管理多個租戶，每個租戶擁有獨立資料庫

租戶 A（企業 A）

super_admin 超級管理員
租戶內最高權限，管理全部功能與帳號

subsidiary_admin
子公司 A1

subsidiary_admin
子公司 A2

hr_manager | dept_manager | employee

租戶 B（企業 B）

super_admin 超級管理員
租戶內最高權限

hr_manager | dept_manager | employee

（完全獨立的資料庫）

平台層

獨立於租戶體系之外，使用 platform.db。專用登入端點，固定最高權限，無 Refresh Token。

租戶全域層

super_admin 為租戶內最高管理者，管理所有功能、帳號與角色。使用 tenant_*.db 獨立資料庫。

子公司 / 部門層

subsidiary_admin 管理特定子公司，dept_manager 管理部門，employee 為一般使用者。權限由 RBAC 矩陣控制。

系統管理總覽

系統設定（租戶內管理）

1. **組織架構管理**
   集團 → 子公司 → 部門三級組織樹
2. **使用者帳號管理**
   建立帳號 + 狀態控制 + 員工關聯
3. **角色權限管理**
   角色定義 + 功能權限矩陣 + 指派
4. **審計日誌**
   安全操作歷史記錄

平台管理（跨租戶管理）

5. **租戶管理**
   建立 / 暫停 / 恢復 / 刪除租戶
6. **訂閱方案管理**
   功能模組 + 使用者上限 + 費用
7. **平台審計日誌**
   跨租戶操作記錄

存取權限：前四功能在「系統設定」下，租戶管理員可見；後三功能在「平台管理」下，僅平台管理員可見。
Multi-tenant：Database-per-Tenant 架構，每租戶獨立資料庫。

三層管理架構 + 預設角色

三層管理架構

平台層 平台管理員

管理所有租戶，獨立於租戶體系

全域層 super_admin

整個租戶，租戶內最高管理者

子公司層 subsidiary_admin

特定子公司，管理該子公司

5 個系統預設角色

super_admin	**超級管理員** — 全域，全功能編輯 + 全公司
subsidiary_admin	**子公司管理員** — 子公司，大部分功能編輯
hr_manager	**人資管理員** — 全域，HR 相關全權限 + 組織管理
dept_manager	**部門主管** — 部門，部門級管理
employee	**一般員工** — 部門，唯讀 + 自身週報提交

系統角色不可刪除，但可修改名稱與權限

三級節點與雙模式展示

三級組織節點

集團 (Group) L0 240 x 160px

最頂層節點，可包含子公司

子公司 (Subsidiary) L1 240 x 120px

法人實體，可包含部門

部門 (Department) L2+ 200 x 90px

業務單位，可包含子部門

雙模式展示

畫布模式

視覺化拖曳、自動佈局、協作線繪製
適合簡報展示與調整佈局

列表模式

階層樹狀表格、快速 CRUD
適合批量管理與快速查看

N	N	N	N
公司數	部門數	員工總數	協作關係

畫布工具與協作關係

工具列功能

視圖切換（畫布/列表） 編輯模式（拖曳+對齊） 協作線顯示（開/關） 網格吸附（開/關）
縮放控制（30%-200%） 匯出 PNG 新增節點

編輯模式工具

選取（全選 / Ctrl 多選） 對齊（靠左/置中/靠右/靠上/置中/靠下） 分布（水平等距 / 垂直等距）
歷史（還原 Ctrl+Z / 重做 Ctrl+Y） 自動整理

協作關係

---- 平行協作 (parallel)

虛線藍色，同級或跨級雙向

---- 下游流程 (downstream)

虛線橘色，單向下游依賴

支援錨點調整（上/下/左/右四邊）

刪除檢查

- 公司需先移除子公司和部門才能刪除
- 部門需先移除子部門和員工

公司與部門管理

新增 / 編輯公司

基本資訊

公司名稱（必） 公司代碼 類型（必：集團/子公司） 上級單位

聯絡資訊

地址 電話 Email

詳細資訊

統一編號 成立日期 營運狀態（營運中/已停止） 公司簡介

新增 / 編輯部門

基本資訊：部門名稱（必）、代碼、主管、上級單位

負責任務：動態新增多筆

KPI 事項：動態新增多筆

職能框架分類：巢狀結構（分類 → 職務）

職務配置：唯讀（顯示職等矩陣的部門職位）

協作關係：與其他部門的關係

使用者帳號管理

使用者清單

使用者（頭像+姓名） 電子郵件 狀態 角色標籤 建立時間 操作（角色管理）

帳號狀態

active（啟用） inactive（停用） locked（鎖定）

新增使用者

1. 點擊新增使用者
2. 填寫（ 姓名（必） Email（必） 密碼（必） 關聯員工 ID ）
3. bcrypt 加密密碼
4. 建立帳號（預設 active）

角色指派

開啟角色管理模態 → 查看目前角色 → 指派新角色 → 功能權限預覽 → 有效權限（合併後）

指派時需選擇：角色 + 作用範圍 + 範圍對象

使用者帳號與員工檔案是分開的概念，不是每位員工都需要帳號。

功能權限矩陣

權限 = 「誰」可以對「哪些功能」做「什麼程度的操作」，看到「多大範圍的資料」

操作等級 — 能做什麼？

none（無權限）

完全看不到功能

view（僅查看）

只能看不能改

edit（可編輯）

完整讀寫權限

資料範圍 — 能看/改多大？

self（個人）

只能存取自己的資料

department（部門）

所屬部門全部資料

company（全公司）

整個租戶全部資料

重要規則：查看範圍 ≥ 編輯範圍（自動確保），調整編輯範圍時系統自動擴大查看範圍。

多角色權限合併：寬鬆策略

合併規則

等級排序：無權限 < 僅查看 < 可編輯

範圍排序：個人 < 部門 < 全公司

合併範例

角色A：L1.profile view/self + 角色B：L1.profile edit/department

↓

最終結果：edit / department

情境範例

陳經理 = 部門主管 + HR 經理

部門主管

員工檔案：edit / 個人（編輯）/ 部門（查看）

HR 經理

員工檔案：edit / 全公司 / 全公司

合併後

edit / 全公司 / 全公司 — 取最高等級 + 最廣範圍

一個使用者可有無限角色，系統自動取各角色最高權限。

常見操作情境

情境 A 新員工入職

使用者管理 → 確認帳號 → 指派「一般員工」角色（全域）

情境 B 升任部門主管

保留原角色 + 新增「部門主管」（作用範圍：行銷部）→ 權限自動合併

情境 C 建立自訂角色

新增角色「招募專員」→ 編輯功能權限（招募+面試+人才庫：edit/全公司）→ 指派

情境 D 確認使用者權限

角色管理 → 查看各角色權限 → 查看有效權限（合併後）

情境 E 暫時撤銷權限

方式一：停用帳號（推薦）
方式二：移除所有角色

情境 F 查看角色使用者

角色卡片 →「已指派 N 位」→ 彈出名單

審計日誌

審計日誌

篩選條件

動作類型（下拉：全部/登入成功/失敗/建立角色/更新/刪除/指派/移除） 開始日期 結束日期

日誌欄位

時間 動作（色彩標記） 資源（auth/user/role） 使用者 IP 詳情（40 字截斷）

支援分頁瀏覽（共 N 筆 / 第 X / Y 頁）

7 種動作類型

login_success	登入成功
login_failed	登入失敗
role_create	建立角色
role_update	更新角色
role_delete	刪除角色
user_role_assign	指派角色
user_role_revoke	移除角色

認證與安全機制

登入方式

租戶登入

組織代碼 + Email + 密碼
POST /api/auth/login

平台管理登入

Email + 密碼
POST /api/auth/platform-login

JWT 雙 Token

Access Token	15 分鐘，localStorage，API 認證
Refresh Token	7 天，localStorage，自動刷新

自動刷新流程：

API 請求 → 401 → 攔截 → 有 Refresh? → 刷新 + 重送

密碼安全

加密：bcryptjs（salt: 10）

最小長度：8 字元

變更後：撤銷所有 Refresh Token

首次登入：must_change_password 強制修改

登入頁面

組織代碼　Email　密碼　記住登入

忘記密碼（目前為模擬）

租戶管理

租戶生命週期

active → suspended → deleted

← 恢復 →　← 恢復 →

各狀態操作

active	編輯、暫停
suspended	編輯、恢復、軟刪除
deleted	恢復、永久刪除

N	N	N
總租戶數	啟用中	已暫停

新增租戶

1. 填寫表單
2. 驗證 slug（僅小寫英文 + 連字號）
3. 建立 tenant record
4. 建立 tenant DB
5. 初始化 Schema（69 業務表 + 7 RBAC 表）
6. RBAC 種子（5 角色 + 權限 + 管理員）
7. 記錄審計日誌

表單欄位

租戶名稱（必）　代碼 slug（必）　Logo　產業別　方案（必）　管理員名稱（必）　管理員信箱（必）　初始密碼（必）

方案管理

方案卡片展示

每張卡片顯示以下資訊：

名稱 | 狀態（啟用/停用） | 月費 / 年費 | 使用者上限 | 儲存空間 | 已啟用功能模組

新增 / 編輯方案

方案名稱（必） | 月費 | 年費 | 使用者上限 | 儲存空間 | 啟用狀態

功能模組授權

三態 checkbox（全選 / 部分 / 無），L1~L6 + SYS 模組與子功能：

L1	員工管理	招募、檔案、入職...
L2	職能管理	職等、JD、框架...
L3	教育訓練	課程、學習地圖...
L4	專案管理	專案、損益、報表...
L5	績效管理	毛利、獎金、評核...
L6	文化管理	手冊、EAP、獎項...
SYS	系統設定	組織、帳號、角色...

平台審計日誌

篩選：動作類型 + 租戶 ID + 日期

12 種動作類型，跨租戶記錄

SUMMARY

系統導入的三大核心效益

組織視覺化

畫布 + 列表雙模式，三級組織樹 + 協作關係，拖曳排列 + 匯出 PNG。

權限精細化

功能權限矩陣（操作等級 x 資料範圍），多角色寬鬆合併，5 預設角色 + 自訂。

安全合規化

JWT 雙 Token 認證，審計日誌全記錄，Database-per-Tenant 租戶隔離。

Q & A

感謝聆聽，歡迎提出任何問題與建議。